Tema 1. Introducción a la Seguridad y al Aseguramiento de la Información

Grupo de Investigación **IDEA**
Departamento de Lenguajes y Sistemas Informáticos
Universidad de Sevilla







Indice

- Objetivos Docentes y Competencias de SSII
- Conceptos Fundamentales
- Requisitos de la seguridad de la información



Objetivos Docentes de SSII



Objetivos Docentes

Desarrollar competencias sobre las tecnologías y aplicaciones relacionados con la implementación de la seguridad de la información en diferentes entornos para alcanzar los objetivos

Saber determinar el grado de cumplimiento de los objetivos de seguridad propuestos



Competencias transversales

Capacidad de organizar y planificar

Determinar las actividades a realizar, la distribución temporal, así como la gestión de los medios, recursos y personas que participarán en proyectos de seguridad de la información

Identificar cuáles son las metodologías y técnicas más adecuadas, elegir entre las posibles alternativas de forma justificada, obtener la solución y verificarla.

Indice

- Objetivos Docentes y Competencias Especificas de SSII
- Conceptos Fundamentales
- Requisitos de la seguridad de la información



Conceptos Fundamentales. Information Security



Seguridad Informática preserva las infraestructuras tecnológicas y de comunicación que soportan la operación de una organización (hardware y software).



Seguridad de la Información (SI) se extiende a todo tipo de soporte, e incluso medidas de seguridad respecto de las personas que la conocen. (Alta Gerencia y Dirección)

Protege de acuerdo a lo conocido y minimiza los efectos de lo desconocido

En la SI. ¿Qué debe estar libre o exento de todo peligro, daño o riesgo?

- Las aplicaciones y el software,
- Equipos hardware,
- Soportes digitales y papel,
- Redes,
- Espacios físicos,
- Procesos de negocio,
- Personas y
- Sobre todo la Información que es un activo que tiene mayor valor y requiere una protección adecuada y **DEBE SER CLASIFICADA.**

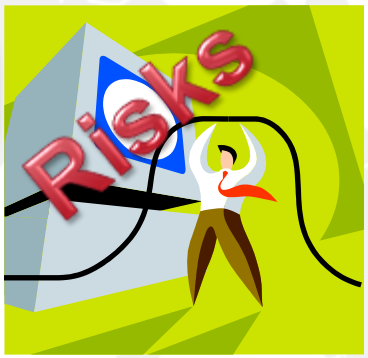
- ***Estrategias*** **relacionadas con la reducción del riesgo mediante:**
  1. ***Defense-in-depth***, (also called layered defenses) aplica multiples salvaguardas (controles para reducir el riesgo) para proteger los activos. Cualquier control de seguridad puede fallar; por desplegar multiples controles, mejoras la confidencialidad, integridad y disponibilidad de la información. (castillo medieval):
     - Puente levadizo, foso, muralla, los torrreones, los arqueros en la muralla, puertas con matacanes, saeteras, troneras, etc.
     - Ningún nivel simple de defensa es infalible; y aún todas estas capas no pueden asegurar un castillo 100% impenetrable.
  2. ***Security through obscurity*** , usa el *secreto* (de diseño, de implementación de aplicaciones, protocolos, etc...) para garantizar la seguridad. No revelación de políticas de seguridad de la información.

3. ***Security by design o open security***, el ***principio de Kerckhoff*** (1880), indica que los diseñadores del sistema deben asumir que el diseño completo de un sistema de seguridad es conocido por los atacantes,
   - Por ejemplo **para el cifrado *"la seguridad reside enteramente en la clave"*.**
4. ***Moving-target defense*** (2008) es una estrategia de "cambio del juego" en seguridad. Se basa en el supuesto que las redes y sistemas de la empresa son dinámicos en el tiempo (constantemente cambiando en términos de configuración del entorno).
   - Esto incrementa la incertidumbre y complejidad para los posibles atacantes, reduce sus ventanas de oportunidad e incremento el costo de sus pruebas y esfuerzos. (ejemplos incluyen cambiar IPs, OSs, puertos en escucha y protocolos, etc.

Los proyectos reales incluyen varias estrategias.

Conceptos Fundamenales.
Consecuencias del No Gobierno SI

- Legales y éticas
- Pérdida de beneficios
- Perjuicio de la reputación
- Deterioro de la confianza del inversor
- Pérdida o compromiso de seguridad de los datos
- Deterioro de la confianza del cliente
- Interrupción de los procesos del negocio



Conceptos Fundamenales.
Consecuencias del No Gobierno SI

Diario de Sevilla

REGÍSTRATE | INICIAR SESIÓN

El Ayuntamiento de Sevilla bloquea todos los servicios por un ciberataque

El Ayuntamiento de Sevilla bloquea todos los servicios por un ciberataque

- Los técnicos trabajan con personal externo para solventar una incidencia que "va para largo" y recuerda al ataque sufrido hace dos años
- Investigan un hackeo tras la caída de la web del Ayuntamiento de Sevilla y su sistema informático
- El Consistorio ya sufrió una ciberestafa que le costó un millón de euros



- Objetivos Docentes y Competencias Especificas de SSII
- Conceptos Fundamentales
- Requisitos de la seguridad de la información



Requisitos de la SI

- ***Integrity*** **is the quality or state of being whole, complete, & uncorrupted. La información y sus métodos de procesamiento deben ser exactos y completos** (evitar cambios de la información **no autorizados o accidentales**),
- ***Confidentiality*** **solo acceden a la información los autorizados** (secreto o privacidad) a los datos y sistemas computacionales *(soluciones técnicas a problemas no técnicos)*
- ***Avaliability*** is making information accessible to authorized user access without interference or obstruction in the required format.(a person or another computer) system

Requisitos de la SI

- ***Identification*** Acto de proveer credenciales que permitan determinar la identidad de un sujeto.
  - ***¿Quién dices que eres?*** Login, ID Card (ATM card, Smart Card, Drivers License),Reconocimiento de cara (combinado con Autenticación) Iris (combinado con Autenticación)



- ***Autenticathion*** Acto de comprobación de las credenciales recibidas con el objetivo de determinar si ***el sujeto es quien dice ser***
  - password, id token, firma digital
- ***Authorization*** Acto de la determinación de los permisos de acceso de un sujeto identificado y autenticado sobre un objeto.
    - Control de Acceso



Requisitos de la SI

- ***Gestión del acceso de usuarios:*** conferir y revocar privilegios y derechos de acceso
    - CRL – Listas de Revocación de Certificados
- ***No-repudio:*** Prueba legal de mensaje enviado o recibido (en origen o destino).
    - Logeado de firmas digitales y copias de mensajes recibidos
- ***Seguridad Física sobre activos***
- ***Service Accountability:*** Posibilidad de conocer ***¿quién hace qué y cuándo?***
- ***Data Accountability:*** Posiblidad de conocer ***¿quién accede a qué datos y qué hace con ellos?***

Especificación de requisitos relacionados con la SI.



Guías son documentos (no obligatorios) que buscan simplificar o ayudar a dirigir un conjunto de procesos con respecto a hábitos/prácticas establecidos en la empresa.



Políticas/Protocolos son obligatorios cuando se adoptan y representan un mapa de acciones/intenciones que sirven de guía a la organización o grupo para la toma de decisiones o lograr los resultados positivos.



Leyes/Reglamentos establecidos por gobiernos de naciones/regiones.



Normas/Estandáres: En Seguridad la serie ISO/IEC27000

No cumplimiento de los requisitos de seguridad.
Delitos informáticos

- **El no cumplimiento de requisitos SI podría permitir:**
  - **Fraude:** Acto deliberado de manipulación de datos perjudicando a una persona física o jurídica que sufre de esta forma una pérdida económica. El autor del delito logra un beneficio normalmente económico.
  - **Sabotaje:** Acción con la que se desea perjudicar a una entidad entorpeciendo deliberadamente sus operaciones, sistemas, programas, etc. El autor no logra normalmente con ello beneficios económicos pero perturba el funcionamiento normal del negocio.

No cumplimiento de los requisitos de seguridad.
Delitos informáticos

- **Chantaje** Acción que consiste en exigir una cantidad de dinero a cambio de no hacer pública cierta información privada o confidencial de una persona física o jurídica y que puede afectar gravemente a su imagen/reputación.
- **Enmascaramiento/Suplantación de identidades:** Utilización indebida de la identidad de otra persona/sistema autorizado. El intruso podría acceder a información confidencial o privada de otros.

Referencias bibliográficas y webgráficas



Instituto Nacional de CiberSeguridad-CERT

https://www.incibe.es/



Criptored. Documentos

http://www.criptored.upm.es/paginas/docencia.htm



Centro Criptológico Nacional

https://www.ccn.cni.es/



ISACA, SANS, NIST, $(ICS)^2$

http://www.isaca.org/spanish/Pages/default.aspx
http://www.sans.org/
http://www.nsrl.nist.gov
https://www.isc2.org/

Referencias bibliográficas y webgráficas

Security Engineering Ross Anderson 2008

- http://www.cl.cam.ac.uk/~rja14/book.html

Encyclopedia of Cryptography and Security de H.C.A. Van Tilborg y S. JaJodia 2ª Edicion. 2011 (disponible en books.google.es)

Handbook of Information Security, Key Concepts, Infrastructure, Standards and Protocols por Hossein Bidgoli 2006 (en books.google.es)

Information Security (Complete Reference Series) de Mark Rhodes-Ousley 2013

Engineering Security de Peter Gutmann 2014